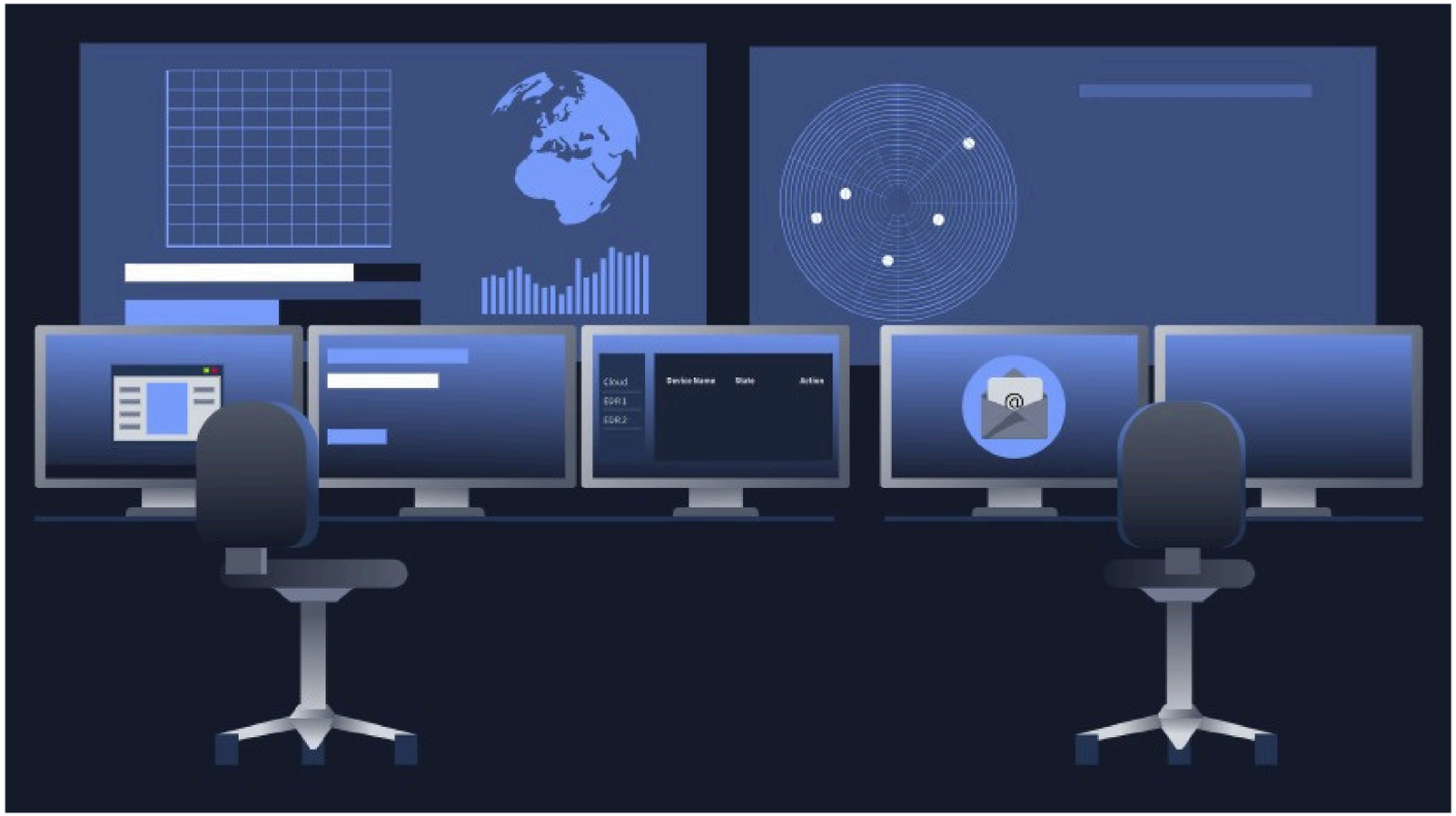
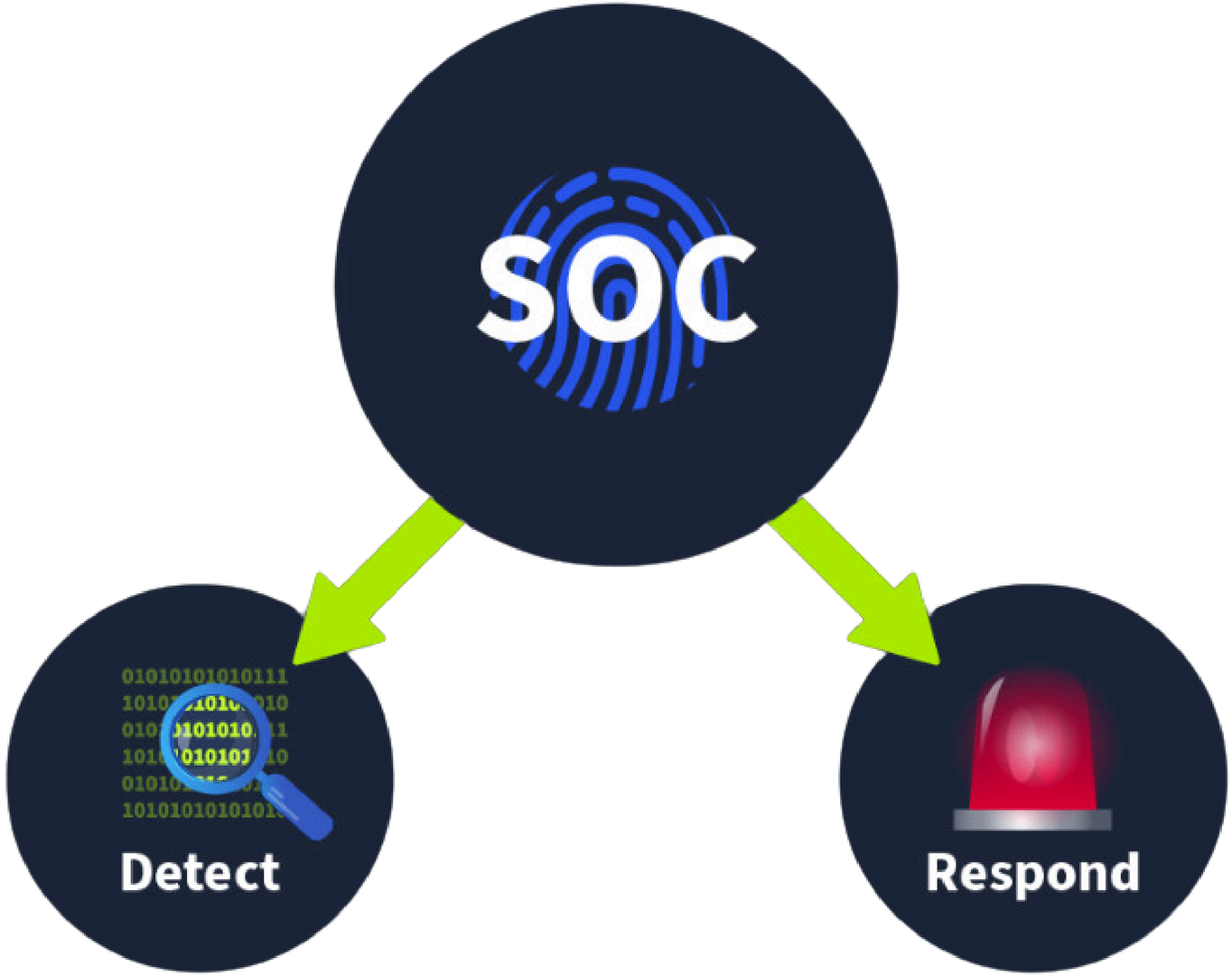
SOC (SECURITY OPERATION CENTER)

Comprehensive Guide to Managing and Investigating Cybersecurity Incidents

HARSHIT BHARDWAJ

A SOC (Security Operations Center) is a dedicated facility operated by a specialized security team. This team aims to continuously monitor an organization's network and resources and identify suspicious activity to prevent damage. This team works 24 hours a day, seven days a week.




SOC
Detect
Respond

DETECTION

- **Detect Unauthorized Activity:** Quickly identify logins using stolen credentials, such as suspicious access from unusual geographic locations.

- **Detect Policy Violations:** Monitor for actions that breach security policies, like downloading pirated files or sending confidential data insecurely.

- **Detect Intrusions:** Identify unauthorized access, such as web app exploits or infections from visiting malicious sites.

RESPONSE

- **Support with the incident response:** Once an incident is detected, certain steps are taken to respond to it. This response includes minimizing its impact and performing the root cause analysis of the incident. The SOC team also helps the incident response team carry out these steps.

THREE PILLARS OF SOC

A SOC environment integrates People,Processes, and Technology. A mature SOC is built on a skilled team utilizing advanced security tools supported by well-defined processes.



PEOPLE

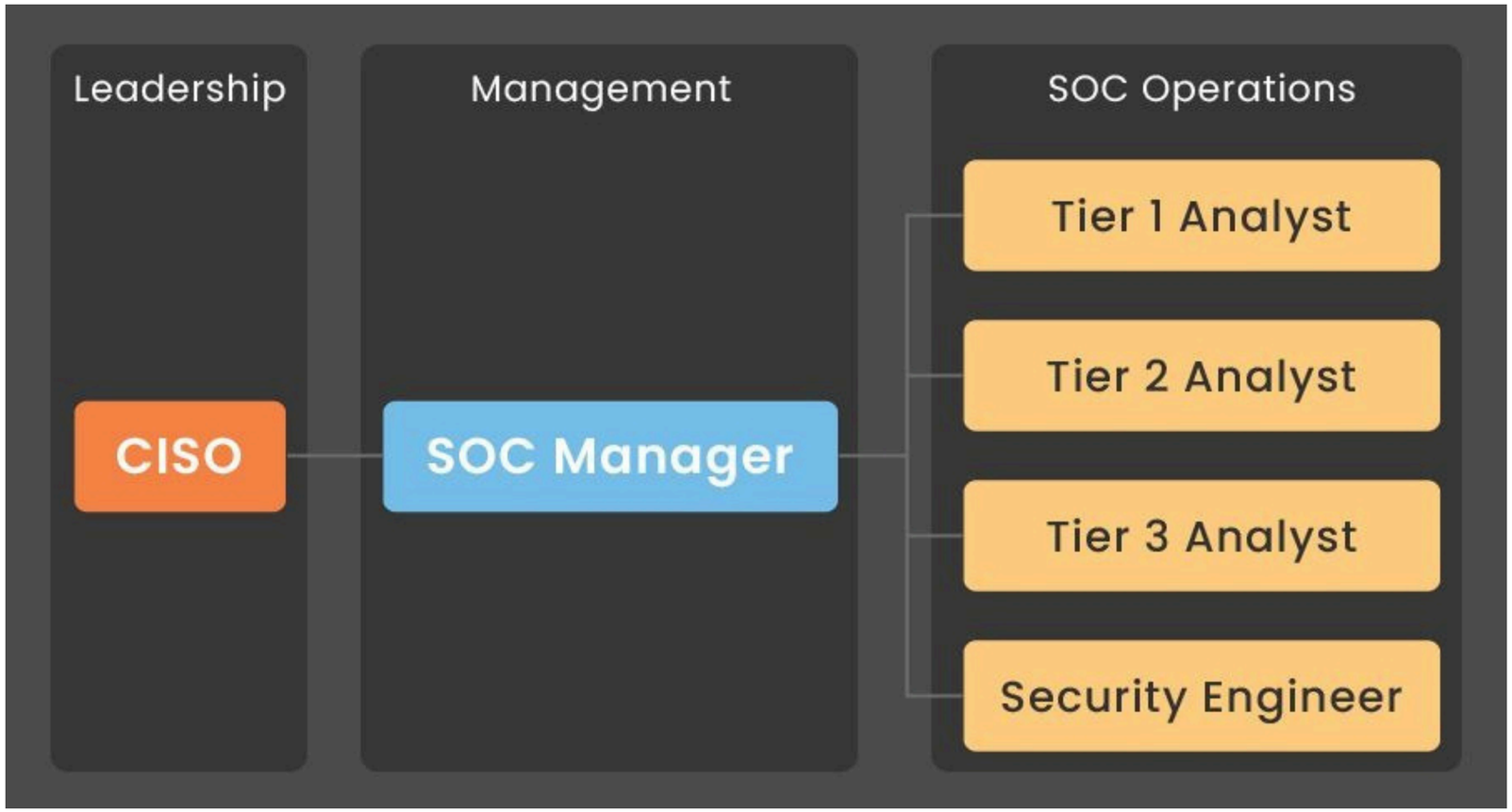
People are very crucial in a SOC as Security solutions can generate numerous alerts, creating significant noise.

Consider a fire brigade relying on centralized software that integrates all city fire alarms. If multiple alerts trigger simultaneously, most caused by cooking smoke, the team wastes time and resources responding to false alarms.

Similarly, in a SOC, relying solely on automated solutions can lead to focusing on irrelevant issues. Human expertise is essential to distinguish genuine threats and ensure a swift, effective response.

PEOPLE

The People are known as the SOC team. This team has the following roles and responsibilities.



PEOPLE

- **SOC Analyst (Level 1):** Thefirstresponders who triage alerts to identify potential threats and escalate harmful detections through proper channels.

- **SOC Analyst (Level 2):** Conduct in-depth investigations, correlate data from multiple sources, and analyze escalated detections.

- **SOC Analyst (Level 3):** Senior experts who proactively hunt threats, lead incident response efforts, and manage containment, eradication, and recovery for critical security incidents.

PROCESS

Each role in a SOC follows specific processes. For instance, Level 1 SOC Analysts act as first responders, performing alert triage to assess potential threats.



ALERT TRIAGE

ALERT TRIAGE

Alert triage forms the foundation of the SOC team, serving as the initial step in responding to any alert. It involves analyzing the alert to determine its severity and prioritization. This process revolves around answering the 5 Ws:

1. **What:** What is the alert about? (Type of threat or activity detected)
2. **When:** When did the event occur? (Timestamp of the alert)
3. **Where:** Where did the alert originate? (Source system, IP, or location)
4. **Who:** Who is involved? (User, account, or entity affected)
5. **Why:** Why is this alert significant? (Potential impact or threat posed)

ALERT TRIAGE

Alert: Malware detected on Host: GEORGE PC

5 Ws	Answers
What?	A malicious file was detected on one of the hosts inside the organization’s network.
When?	The file was detected at 13:20 on June 5, 2024.
Where?	The file was detected in the directory of the host: "GEORGE PC".
Who?	The file was detected for the user George.
Why?	After the investigation, it was found that the file was downloaded from a pirated software-selling website. The investigation with the user revealed that they downloaded the file as they wanted to use a software for free.

REPORTING

Harmful alerts should be promptly escalated to higher-level analysts for timely response and resolution. These alerts are converted into tickets and assigned to the appropriate personnel. The report must include a detailed analysis covering all 5 Ws, along with relevant screenshots as evidence of the detected activity.

INCIDENT RESPONSE AND FORENSICS

When reported detections indicate critical malicious activities, a high-level team initiates an incident response. In some cases, a thorough forensic investigation is also necessary to determine the root cause of the incident by analyzing system or network artifacts.

TECHNOLOGY

An organization's network consists of many devices and applications. As a security team, individually detecting and responding to threats in each device or application would require significant effort and resources.

Security solutions centralize all the information of the devices or applications present in the network and automate the detection and response capabilities.

TECHNOLOGY

SIEM: Security Information and Event Management (SIEM) is widely used in SOCs to collect logs from network devices. It uses detection rules to identify suspicious activity by correlating logs from multiple sources. Modern SIEMs go beyond rule-based detection, offering user behavior analytics, threat intelligence, and machine learning to improve detection capabilities.

splunk>

TECHNOLOGY

EDR: Endpoint Detection and Response (EDR)gives the SOC team detailed visibility into endpoint activities, both in real-time and historically. It operates at the endpoint level and offers automated responses, enabling quick investigation and response with minimal effort.

Firewall: A firewall serves as a network security barrier between internal and external networks, such as the internet. It monitors and filters incoming and outgoing traffic, blocking unauthorized access. Firewalls also use detection rules to identify and block suspicious traffic before it reaches the internal network.

What are IOCs?

Indicators of Compromise (IOCs) are forensic artifacts that indicate a system has already been compromised.

Common IOC Examples:

- Malicious file hashes (MD5, SHA-256)
- Known malicious IP addresses
- Suspicious domains or URLs
- Malware filenames or registry keys
- Log entries indicating confirmed malicious activity

Key Characteristics:

- Reactive in nature
- Easy to detect but easy to evade
- Useful for confirmation and blocking known threats

What are IOAs?

Indicators of Attack (IOAs) focus on attacker behavior rather than known malicious artifacts. They help detect attacks while they are in progress or before compromise.

Common IOA Examples:

- PowerShell spawned from Microsoft Word
- Multiple failed login attempts followed by success
- Credential access tools executed from user directories
- Unusual process execution chains

Key Characteristics:

- Behavior-based detection
- Harder for attackers to evade
- Enables early detection and prevention

IOC vs IOA

Aspect	IOC	IOA
Detection Type	Artifact-based	Behavior-based
Timing	Post-compromise	Pre- or mid-attack
Evasion	Easy	Difficult
Use Case	Blocking known threats	Detecting unknown attacks

Real-World Example

- **IOC:** Known ransomware hash detected by antivirus
- **IOA:** Office document spawning PowerShell and attempting network connections

Both together provide stronger detection coverage.

TTPs

TTPs - Tactics, Techniques, and Procedures

What are TTPs?

TTPs describe how attackers operate during an attack.

- **Tactics:** The attacker's objective (e.g., Initial Access)
- **Techniques:** How the objective is achieved (e.g., Phishing)
- **Procedures:** Exact implementation details used by the attacker

MITRE ATT&CK

MITRE ATT&CK is a globally adopted framework that documents known adversary behaviors across the attack lifecycle.

Why SOCs Use MITRE ATT&CK:

- Standardized attack language
- Helps map detections to real attacker behavior
- Improves detection engineering and threat hunting

Correlating TTPs with IOCs and IOAs

- **TTPs** explain what the attacker is trying to do
- **IOAs** detect how the attacker is behaving
- **IOCs** confirm what malicious artifacts were left behind

Together, they enable context-driven detection instead of alert-driven noise.

Mapping an Attack Lifecycle Using TTPs

Example Attack Flow:

- Initial Access – Phishing email (Tactic)
- Execution – PowerShell execution (Technique)
- Credential Access – Credential dumping attempt
- Command & Control – External IP communication
- Impact – Ransomware execution

Each stage can be mapped to:

- TTP (MITRE)
- IOA (behavior)
- IOC (artifact)

Key SOC Performance Metrics

Mean Time to Detect (MTTD)

- The average time taken by the SOC to identify a security incident after it occurs.
- Lower MTTD means faster threat visibility and reduced attacker dwell time.

Mean Time to Respond (MTTR)

- The average time taken to contain, remediate, and close an incident after detection.
- Lower MTTR means reduced impact and faster recovery.

Key SOC Performance Metrics

Why MTTD and MTTR Matter

- Measure SOC speed and efficiency
- Indicate detection and response maturity
- Directly impact business risk and downtime
- Used by management to evaluate SOC performance

Relationship with IOC, IOA, and TTP

- IOAs & TTP-based detections → **Reduce MTTD**
- Clear triage, playbooks, and automation → **Reduce MTTR**
- IOC-only detection → **Higher MTTD**

SETTING UP A SOC LAB: CONFIGURING SPLUNK



WHY SPLUNK?

Centralized Log Management: Splunk efficiently collects, indexes, and analyzes logs from various devices, providing real-time insights into security events.

Threat Detection: It offers powerful search features and pre-built detection rules to identify suspicious activity and integrate with threat intelligence feeds.

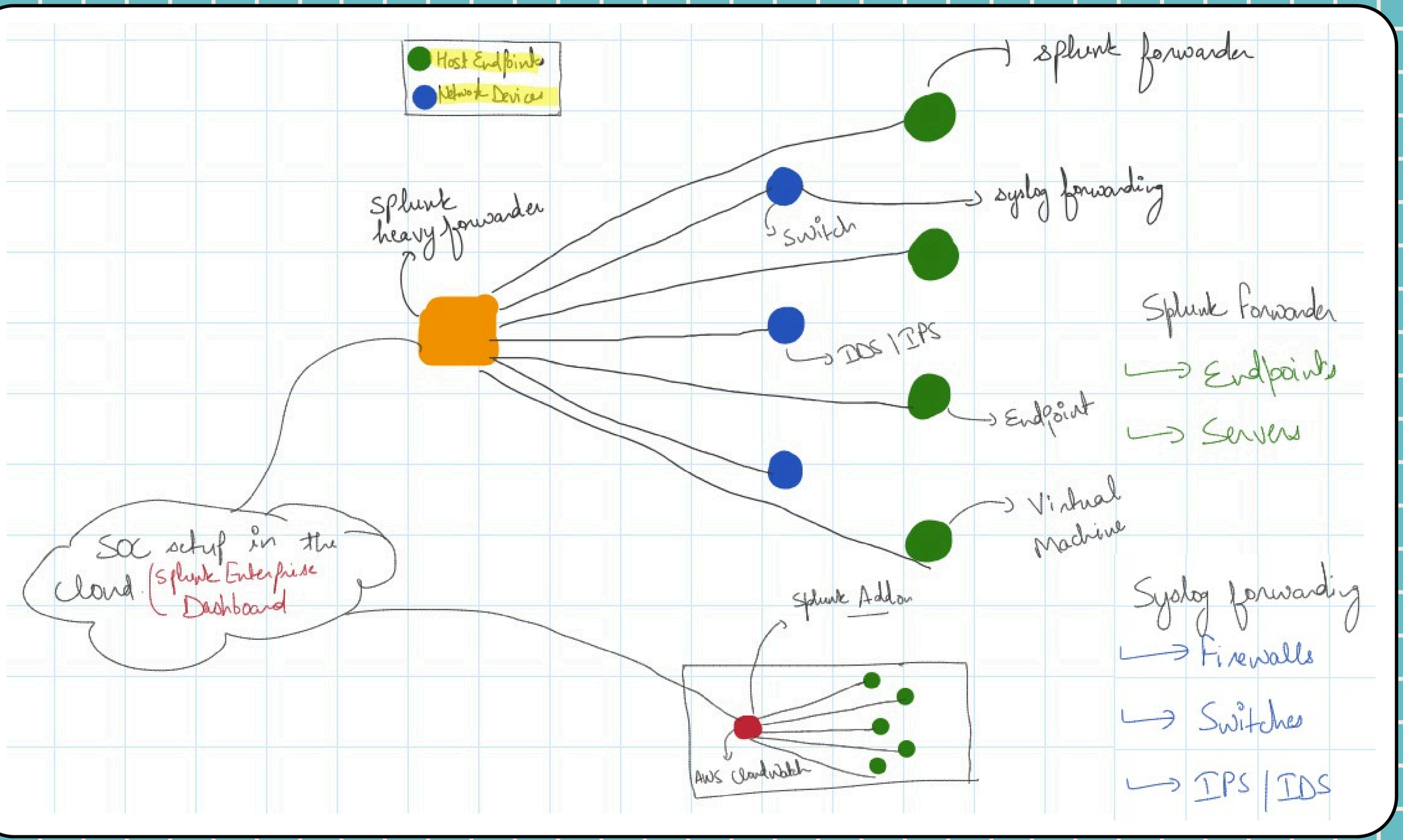
Scalability & Flexibility: Splunk is scalable and customizable, handling diverse data sources and allowing tailored dashboards, reports, and alerts.

WHY SPLUNK?

Centralized Log Management: Splunk efficiently collects, indexes, and analyzes logs from various devices, providing real-time insights into security events.

Threat Detection: It offers powerful search features and pre-built detection rules to identify suspicious activity and integrate with threat intelligence feeds.

Scalability & Flexibility: Splunk is scalable and customizable, handling diverse data sources and allowing tailored dashboards, reports, and alerts.


Host Endpoints
Network Devices
splunk forwarder
splunk heavy forwarder
switch
syslog forwarding
IDS / IPS
Endpoint
Virtual Machine
SOC setup in the cloud (Splunk Enterprise Dashboard)
Splunk Addon
AWS cloudwatch
Splunk forwarder
→ Endpoints
→ Servers
Syslog forwarding
→ Firewalls
→ Switches
→ IPS / IDS

① splunk Universal forwarder is installed on the endpoints.
↳ Host Machine

② By using the syslog forwarding, the logs from the networking devices are forwarded
↳ firewalls, switches

③ Then the data is sent to the splunk heavy forwarder.
↳ Splunk's heavy forwarder parses data before forwarding it.

Note: For Smaller Networks, we do not need to have a heavy forwarder in place. we can directly logs from our splunk universal forwarder to splunk Manager.

① splunk Universal forwarder is installed on the endpoints.
↳ Host Machine

② By using the syslog forwarding, the logs from the networking devices are forwarded
↳ firewalls, switches

③ Then the data is sent to the splunk heavy forwarder.
↳ Splunk's heavy forwarder parses data before forwarding it.

Note: For Smaller Networks, we do not need to have a heavy forwarder in place. we can directly logs from our splunk universal forwarder to splunk Manager.

RESOURCES FOR INSTALLATION

Home Lab Series: Setting Up and Configuring Splunk for Security Monitoring

SOC IMPLEMENTATION

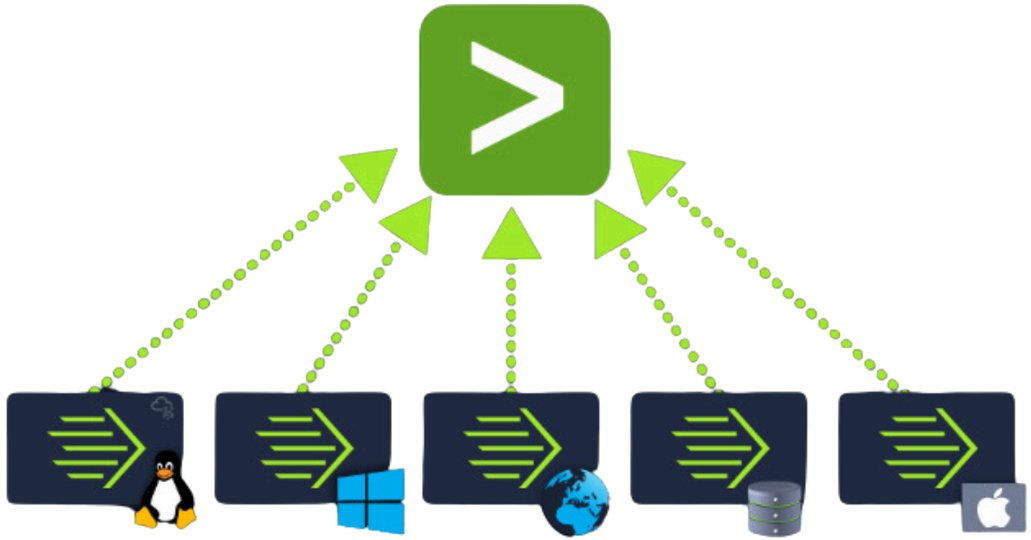
SPLUNK COMPONENTS

Splunk has three main components, namely Forwarder, Indexer, and Search Head. These components are explained below:



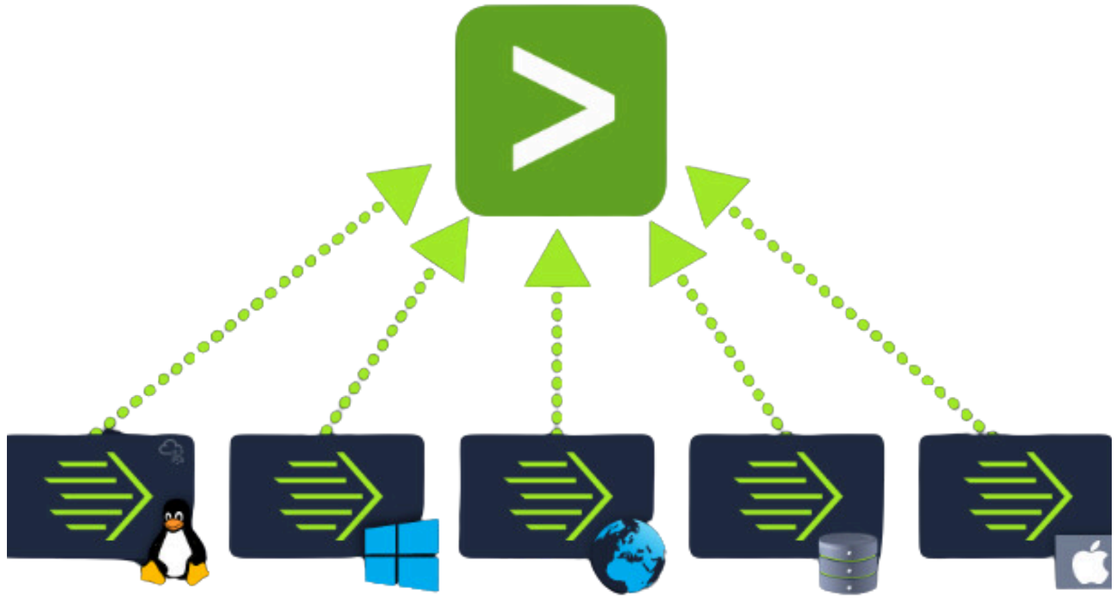
SPLUNK FORWARDER

Splunk Forwarder is a lightweight agent installed on the endpoint intended to be monitored, and its main task is to collect the data and send it to the Splunk instance.



SPLUNK FORWARDER

- Web servergenerating webtraffic.
- Windows Event Logs, PowerShell, and Sysmon data.
- Linux host generating host-centric logs.
- DB connection requests, responses, and errors.



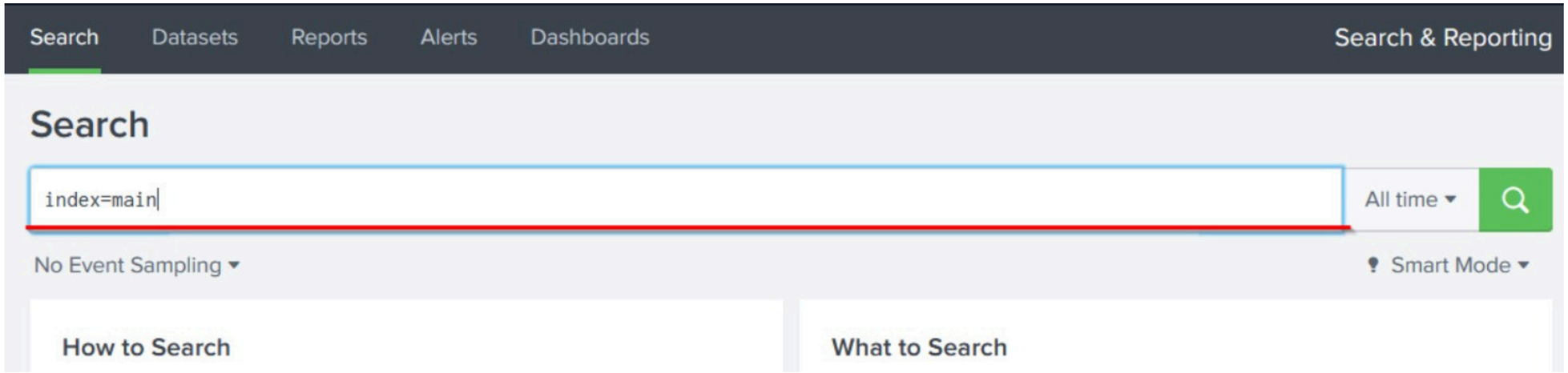
SPLUNK INDEXER

- Splunk Indexer plays themain role in processing the data it receives from forwarders. It takes the data, normalizes it into field-value pairs, determines the datatype of the data, and stores them as events. Processed data is easy to search and analyze.



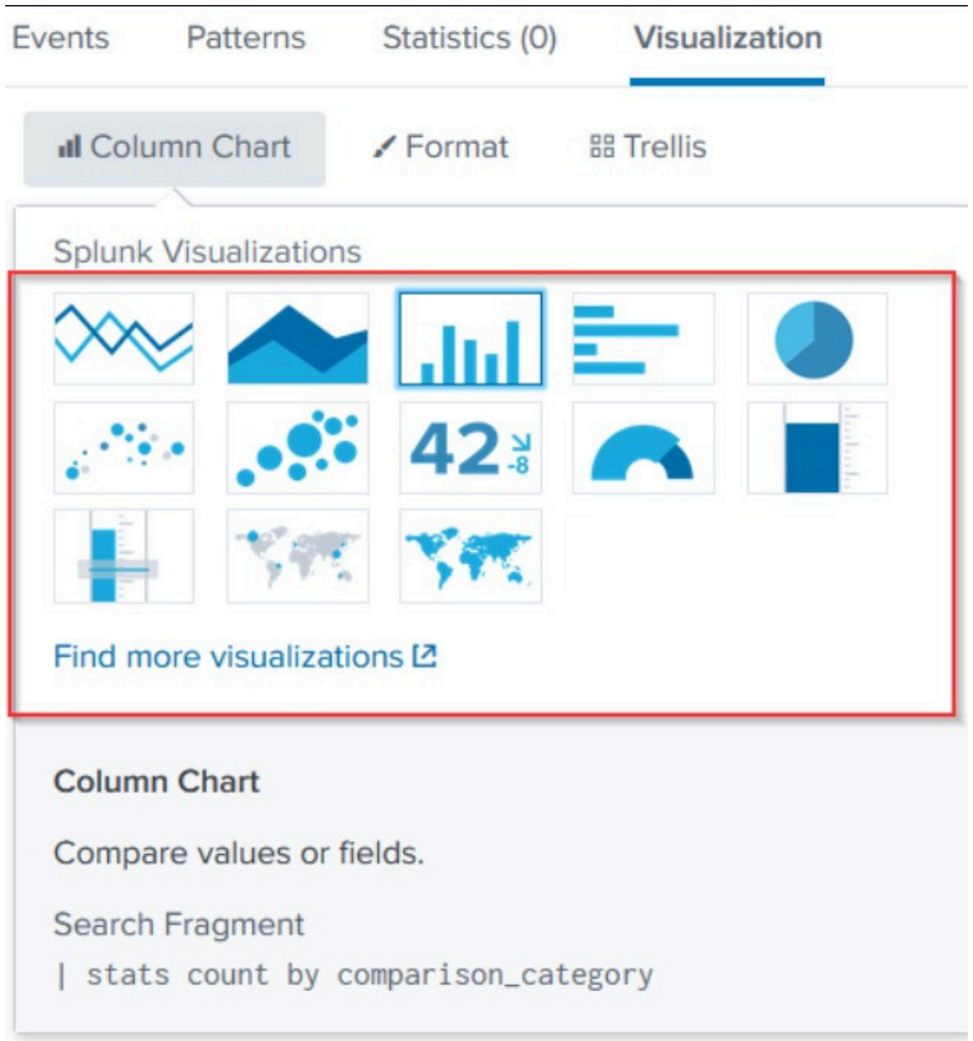
SEARCH HEAD

- Splunk Search Head is the placewithin the Search & Reporting App where users can search the indexed logs as shown below. When the user searches for a term or uses a Search language known as Splunk Search Processing Language, the request is sent to the indexer and the relevant events are returned in the form of field-value pairs.



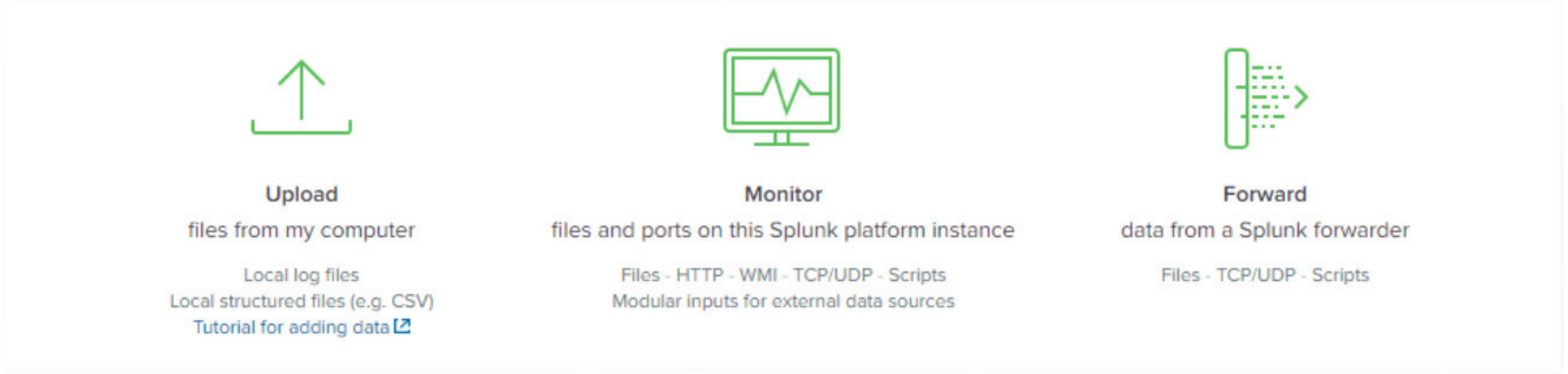
SEARCH HEAD

- Search Head alsoprovides the ability to transform the results into presentable tables, visualizations like pie-chart, bar-chart and column-chart, as shown below:



GETTING DATA INTO SPLUNK

- **Upload:** Manuallyupload datafiles (e.g., CSV, logfiles)into Splunk for one-time ingestion.
- **Monitor:** Continuously monitor files directories, automatically ingesting new data as it's added.
- **Forward:** Use Splunk Forwarders to send log data from remote systems to a central Splunk instance.



THANK YOU!

Harshit Bhardwaj